AI GOVERNANCE EVIDENCE PACK

Harrow & Vale LLP

AI inventory, use policy, approvals, staff training and security-questionnaire responses

Document ID	HV-AIG-PACK-001 · Version 1.1
Status	Approved by client, 27 October 2026
Engagement period	6 – 27 October 2026 (15 working days)
Trigger	Supplier security questionnaire (SIG-based, with AI section) from the firm's largest client, a regional bank; due 5 November 2026
Client owner	Dana Whitlock, Managing Partner
Client AI governance lead	Priya Raman, Director of Operations & IT
Prepared by	[MSP name] AI Governance Services
Next review	27 January 2027 (quarterly)

Contents

1. Engagement summary and findings
2. AI system inventory (HV-AIG-INV-001)
3. AI acceptable use policy (HV-AIG-POL-001)
4. Tool approvals log (HV-AIG-APR-001)
5. AI literacy training record (HV-AIG-TRN-001)
6. Security questionnaire — AI section responses (HV-AIG-QST-001)
7. Evidence index and framework mapping (HV-AIG-EVD-001)

Sample document. Harrow & Vale LLP, its people, client and engagement are fictional. This pack shows the format and depth of a real delivery. Questionnaire wording is paraphrased, not copied from licensed questionnaires. In live engagements every answer is verified with the client and signed off by them before submission.

1. Engagement summary

About the client

Harrow & Vale LLP is an accounting, tax and advisory firm with 48 staff: 42 in Columbus, Ohio, and 6 in Manchester, UK. It prepares tax returns, audits and advisory work for about 900 businesses and individuals. IT runs on Microsoft 365 Business Premium, managed by [MSP name]. Staff mostly use ChatGPT and Claude; Microsoft 365 Copilot Chat is available to everyone through their work sign-in.

Why this work happened

On 2 October 2026 the firm's largest client, a regional bank, sent its annual supplier security questionnaire. This year it contained a new section of 14 questions on AI: inventory, policy, approvals, data handling, training and third-party AI. The firm had no written answers and no evidence behind them.

What we found (discovery, 6 – 10 October)

Area	Finding	Severity
Inventory	9 AI tools in use; leadership knew of 3. Found via Microsoft Defender for Cloud Apps discovery, Entra ID enterprise-app consents, a 10-question staff survey (44 of 48 replied) and interviews with 4 team leads.	High
Client data in personal AI	11 staff used personal ChatGPT, Gemini or Claude accounts for work; 4 said they had pasted client financial details. US tax return information has use and disclosure limits (IRC §7216) and is in scope of the FTC Safeguards Rule.	Critical
Meeting bots	A free AI note-taker was joining client calls from 3 staff calendars, recording without a consent step and storing transcripts with the vendor.	Critical
Policy	No AI policy. The 2023 acceptable use policy does not mention AI.	High
Approvals	No approval route for new AI tools or AI features in existing software.	High
Training	No AI training or acknowledgement records.	Medium
Paid AI accounts	9 staff paid for ChatGPT Plus or Claude Pro on personal or company cards. No business workspace, no single sign-on, no admin control, and accounts would stay with the person if they left.	High

What changed (11 – 27 October)

- Inventory of 9 tools with a decision for each: 4 approved, 3 restricted, 2 banned (section 2).
- One-page AI acceptable use policy approved by the Managing Partner on 20 October (section 3).
- ChatGPT Business and Claude Team workspaces set up on 15 October with Entra ID single sign-on and verified company domain; 9 paid personal accounts closed and staff moved across. Uploads to personal AI and the note-taker blocked in Defender for Cloud Apps; note-taker app consent revoked in Entra ID on 14 October.
- 45-minute AI literacy session delivered twice; 48 of 48 staff trained and acknowledged by 24 October (section 5).
- 14 questionnaire answers drafted, verified with the client and approved for submission (section 6).

Open items (tracked, owner Priya Raman): renew the tax software vendor's AI addendum by 31 Dec 2026 (APR-007); confirm the website chatbot vendor's data retention in writing by 15 Nov 2026 (APR-008); quarterly review on 27 Jan 2027.

2. AI system inventory HV-AIG-INV-001 · as at 27 Oct 2026

Every AI tool or AI feature used for firm work, how it was found, what data it may touch and the decision taken. Data classes: **Public**, **Internal**, **Confidential** (client financial and tax data, HR, personal data).

ID	Tool / feature	Owner	Users	Use and data	Decision	Conditions / controls
AI-01	ChatGPT Business (company workspace)	P. Raman	22 seats	Drafting, summaries, spreadsheet analysis. Up to Confidential.	Approved	Business terms: workspace data not used for model training. Entra ID SSO; domain verified so staff cannot create stray workspaces. Memory off; no third-party connectors without approval.
AI-02	Claude Team (company workspace)	Advisory lead	8 seats	Long-document review, report drafting. Up to Confidential.	Approved	Commercial terms: no training on firm data by default. SSO; projects shared only within engagement teams. Connectors off unless approved.
AI-03	Microsoft 365 Copilot Chat (free, work sign-in)	P. Raman	All staff	General drafting and research. Up to Internal.	Approved	Work account only, enterprise data protection. No client names or figures.
AI-04	Teams Premium meeting recap	P. Raman	Partners, managers	Internal meeting notes. Client calls only with consent.	Approved	Consent line read at start of client calls; transcripts kept 90 days.
AI-05	Tax & practice software AI assistant (vendor-embedded)	Tax partner	Tax team (17)	Research and return review. Confidential.	Restricted	Research mode only until vendor AI addendum is renewed (APR-007). Reviewer signs every return as usual.
AI-06	Website chatbot (vendor-hosted)	Marketing lead	Public visitors	Answers FAQs, books calls. Public; captures name and email.	Restricted	Tells visitors they are talking to AI. No tax or account questions; hands off to staff. Retention to be confirmed (APR-008).
AI-07	ChatGPT, Gemini, Claude — personal accounts	—	11 found	Was used with client data.	Restricted	Public data only, never client or firm data. Uploads blocked in Defender for Cloud Apps. Staff moved to AI-01 and AI-02.
AI-08	Free AI meeting note-taker bot	—	3 calendars	Recorded client calls without consent.	Banned	App consent revoked; domain blocked; vendor asked to delete stored recordings (confirmation on file, EV-09).
AI-09	Browser AI extensions (summarisers, PDF chat)	—	5 devices	Read page content, including client portals.	Banned	Removed via Intune; extension allow-list enforced in Edge and Chrome.

Discovery sources: Defender for Cloud Apps (30-day log, 6 Oct), Entra ID enterprise apps and consents, Intune device extension report, staff survey (44/48 responses), 4 team-lead interviews. New tools are added only through the approval route in the policy.

3. AI acceptable use policy HV-AIG-POL-001 · v1.0 · effective 21 Oct 2026

Purpose. To let our people use AI to work better while protecting client data, meeting our legal duties and keeping professional judgment with a person.

Applies to all partners, staff, contractors and interns in the US and UK, on any device used for firm work.

1. Use only approved tools

The approved list is the AI inventory (HV-AIG-INV-001), kept on the intranet. If a tool is not on it, do not use it for firm work. This includes AI features newly switched on inside software we already use.

2. Match the data to the tool

Data	Examples	Allowed in
Public	Published tax guidance, our website	Any approved tool; personal AI accounts
Internal	Templates, internal notes without client details	AI-01, AI-02, AI-03, AI-04
Confidential	Client financial and tax data, personal data, HR, engagement letters	AI-01 and AI-02 (company workspaces only, signed in with your work account), and AI-05 in its approved mode

Never enter passwords, bank or card numbers, or Social Security / National Insurance numbers into any AI tool.

3. A person stays responsible

You own anything you send, file or sign, whoever drafted it. Check AI output against source documents. AI must not make final decisions on tax positions, audit opinions, hiring or client acceptance.

4. Be open about AI

Ask for consent before any AI transcription of a client call. Our website chatbot must say it is AI. Tell your manager if AI produced a material part of a client deliverable.

5. New tools and features

Request through the IT helpdesk form "AI tool request". The AI governance lead decides within 5 working days, using the approval checklist (data use, training on our data, retention, location, security terms, US and UK privacy terms). Decisions are logged in HV-AIG-APR-001.

6. Training

Everyone completes AI literacy training on joining and once a year, and acknowledges this policy.

7. Report problems

If client data went into an unapproved tool, or AI output caused an error, tell the AI governance lead the same day. We handle it as a security incident under the incident response plan; no blame for reporting promptly.

8. Breaches and review

Breaches are handled under the staff handbook. The policy is reviewed every 12 months, or sooner if the law, our tools or our clients' requirements change.

Owner	Priya Raman, Director of Operations & IT
Approved by	Dana Whitlock, Managing Partner — 20 Oct 2026

4. Tool approvals log HV-AIG-APR-001

Each decision checks: what data the tool sees; whether the vendor trains on it; retention and deletion; where data is stored; security terms (SOC 2 / ISO 27001 report or equivalent); and whether US and UK privacy terms are covered.

Ref	Tool	Date	Decision	Basis	Decided by	Review
APR-001	AI-01	13 Oct 2026	Approved	Business terms exclude training on workspace data; DPA signed; SSO and domain verification required before go-live (done 15 Oct).	P. Raman; D. Whitlock	Jan 2027
APR-002	AI-02	13 Oct 2026	Approved	Commercial terms exclude training by default; DPA signed; limited to advisory and audit teams who asked for it.	P. Raman; D. Whitlock	Jan 2027
APR-003	AI-03	13 Oct 2026	Approved	Included with M365; work sign-in gives enterprise data protection. Limited to Internal data for simplicity.	P. Raman	Jan 2027
APR-004	AI-04	13 Oct 2026	Approved	Inside M365 tenant; consent script added to client-call template.	P. Raman	Jan 2027
APR-005	AI-07	14 Oct 2026	Restricted	Consumer terms; no firm control over retention or training settings. Public data only.	P. Raman; D. Whitlock	Jan 2027
APR-006	AI-08	14 Oct 2026	Banned	Recorded clients without consent; vendor keeps recordings; no business agreement.	D. Whitlock	—
APR-007	AI-05	17 Oct 2026	Restricted	Vendor AI terms expire 31 Dec 2026; research mode only until renewed addendum confirms no training on client data and §7216 handling.	Tax partner; P. Raman	31 Dec 2026
APR-008	AI-06	17 Oct 2026	Restricted	Public FAQ only, AI disclosure shown, hands off to staff. Written retention terms requested.	P. Raman	15 Nov 2026
APR-009	AI-09	14 Oct 2026	Banned	Extensions can read client portal pages; no business need that AI-01 doesn't meet.	P. Raman	—

5. AI literacy training record HV-AIG-TRN-001

Session	"Using AI safely at Harrow & Vale" — 45 minutes, live on Teams, recorded
Delivered	22 Oct 2026, 10:00 ET (US) and 23 Oct 2026, 14:00 UK (Manchester); recording for 3 absentees
Trainer	[MSP name] AI Governance Services
Check	8-question quiz, pass mark 7/8; then policy acknowledgement in Microsoft Forms

Content

1. What AI tools do well and badly: confident wrong answers, invented citations, out-of-date tax rules.
2. Our approved tools (ChatGPT Business, Claude Team, Copilot Chat) and what each may be used for; how to sign in to the company workspace, not a personal account.
3. Data rules with real examples: which client documents may go where.
4. Client calls and consent; the website chatbot.
5. Checking output: three-step review for anything going to a client.
6. How to request a new tool and how to report a mistake.

Completion by team

Team	Headcount	Trained	Quiz passed	Policy acknowledged	Completed by
Partners	6	6	6	6	22 Oct
Tax	17	17	17	17	24 Oct
Audit & assurance	11	11	11	11	23 Oct
Advisory (incl. Manchester 6)	8	8	8	8	23 Oct
Operations, IT, marketing	6	6	6	6	22 Oct
Total	**48**	**48**	**48** (3 on second attempt)	**48**	**24 Oct**

Named attendance export (Teams report), quiz results and acknowledgements (Forms export) are held as EV-11 to EV-13. New starters complete the recording and quiz in their first week; annual refresher due October 2027.

6. Security questionnaire — AI section HV-AIG-QST-001

Questions paraphrased from the client's SIG-based questionnaire. Answers approved by D. Whitlock on 27 Oct 2026. Each answer points to evidence in section 7.

#	Question	Answer	Response	Evidence
1	Do you keep an inventory of AI systems and AI features used to deliver services?	Yes	Inventory of 9 tools with owner, users, data class and decision, updated through the approval route and reviewed quarterly.	EV-01, EV-02
2	Do you have a documented AI use policy, approved by management?	Yes	AI acceptable use policy approved by the Managing Partner on 20 Oct 2026, reviewed annually.	EV-03
3	Has the policy been communicated to and acknowledged by staff?	Yes	48 of 48 staff acknowledged by 24 Oct 2026; required at onboarding.	EV-13
4	Is there a process to approve new AI tools before use?	Yes	Helpdesk request; decision within 5 working days against a written checklist; logged.	EV-04
5	Will our data be processed by AI? If so, which systems?	Yes, limited	Only in our company ChatGPT Business and Claude Team workspaces (single sign-on, no training on our data), and the tax software assistant in research mode. No other AI tool may receive your data.	EV-01, EV-04
6	Is our data used to train AI models?	No	Approved tools' contract terms exclude training on our content. Tools without such terms are restricted to public data or banned.	EV-05
7	How do you stop staff using unapproved AI with client data?	Controls	Policy and training; uploads to personal AI blocked in Defender for Cloud Apps; browser extension allow-list via Intune; monthly discovery report.	EV-06, EV-07
8	Is AI output reviewed by a person before it affects us?	Yes	Policy section 3: a named person is accountable for every deliverable; AI cannot make final tax, audit or acceptance decisions.	EV-03
9	Do you provide AI training to staff?	Yes	45-minute AI literacy training with a quiz; 100% completion; annual refresher.	EV-11, EV-12
10	Do you assess the security and privacy of third-party AI providers?	Yes	Checklist covers data use, retention, location, security attestations and privacy terms; renewal tracked (APR-007).	EV-04, EV-05
11	Do you use AI to record or transcribe meetings with us?	Only with consent	Teams Premium recap only, after your consent at the start of the call. Third-party note-taker bots are banned.	EV-08, EV-09
12	Who is accountable for AI governance?	Named	Priya Raman, Director of Operations & IT; oversight by the Managing Partner.	EV-03
13	Are AI-related incidents covered by your incident response process?	Yes	Policy section 7 routes AI misuse and AI errors into the incident response plan; same-day reporting.	EV-03, EV-14
14	Have you had any AI-related incident involving client data in the last 12 months?	Disclosed	Before 14 Oct 2026, some staff used personal AI accounts and a note-taker bot. Found by our own review; access removed, vendor deletion confirmed. No use of your data was identified.*	EV-09, EV-10

* In a live engagement this answer is written only from facts the client confirms, and the client decides with its advisers how to disclose.

7. Evidence index and framework mapping HV-AIG-EVD-001

ID	Evidence	Date	Location
EV-01	AI inventory (this pack, section 2)	27 Oct 2026	SharePoint › Governance › AI
EV-02	Defender for Cloud Apps discovery report (30 days)	6 Oct 2026	Same folder, /discovery
EV-03	Signed AI acceptable use policy	20 Oct 2026	Policies library
EV-04	Approvals log and checklist	17 Oct 2026	SharePoint › Governance › AI
EV-05	Vendor terms and DPAs (OpenAI, Anthropic, Microsoft, tax software)	13 – 17 Oct 2026	/vendors
EV-06	Defender for Cloud Apps policies (screenshots)	14 Oct 2026	/controls
EV-07	Intune extension allow-list configuration	14 Oct 2026	/controls
EV-08	Client-call consent script and Teams policy	13 Oct 2026	/controls
EV-09	Note-taker consent revocation and vendor deletion confirmation	14 – 21 Oct 2026	/incidents
EV-10	Incident record INC-2026-031 (personal AI use)	14 Oct 2026	/incidents
EV-11	Training slides and Teams attendance export	22 – 23 Oct 2026	/training
EV-12	Quiz results export	24 Oct 2026	/training
EV-13	Policy acknowledgements export	24 Oct 2026	/training
EV-14	Incident response plan v3.2 (AI section added)	21 Oct 2026	Policies library

Framework mapping

Deliverable	ISO/IEC 42001:2023 Annex A	NIST AI RMF 1.0	Other
AI inventory	A.4.2 resource documentation; A.9.4 intended use	GOVERN 1.6	EU AI Act Art. 26 (deployer duties, where applicable)
AI use policy	A.2.2 AI policy; A.3.2 roles and responsibilities; A.9.2 responsible use	GOVERN 1.2, 2.1	FTC Safeguards Rule 16 CFR 314.4(c)
Approvals and vendor checks	A.10.3 suppliers; A.7.2 data for AI	GOVERN 6.1; MANAGE 3.1	IRC §7216; UK GDPR Art. 28
Training record	A.4.6 human resources (competence)	GOVERN 2.2	EU AI Act Art. 4 (AI literacy)
Transparency (calls, chatbot)	A.8.2 information for users	GOVERN 4.2; MAP 1.1	EU AI Act Art. 50
Incident handling	A.8.4 communication of incidents	MANAGE 4.3	FTC Safeguards Rule 314.4(h)

Mapping shows where each deliverable supports a control; it is not a certification or legal opinion. EU AI Act references apply only where the firm's AI use falls within the Act's scope (e.g. EU clients or users).

Client approval — Dana Whitlock, Managing Partner
27 Oct 2026

Prepared by — [MSP name] AI Governance Services
27 Oct 2026